

Azure Configuration Checklist

Hands-on setup for Cloud Compliance & Governance Controls and Cloud Security Operations & Incident Response — check off each step as you complete it in your own Azure subscription, and note where the evidence (screenshot, export, event ID) landed so it's ready to drop into the matching PDF submission.

Scenario: Horizon Valley Medical Center (HVMC) **Project:** AccessGuard Health **Prepared for:** Sabitha S Karanavar **Date:** October 7, 2026

Platform note: this checklist was originally drafted around AWS services. HVMC's actual lab subscription is Microsoft Azure, so every step below uses the Azure equivalent (Management Groups, Azure Policy, Microsoft Defender for Cloud, Azure Monitor) and references your real resource group, `HVMC-CloudSecurity-RG`, and its existing resources (`HVMC-Prod-VNet` , `HVMC-Web/App/Data-NSG` , `HVMC-Bastion`).

A. Cloud Compliance & Governance Controls

Replaces the illustrative Azure Policy/tagging/compliance-scan evidence in *HVMC_Cloud_Compliance_and_Governance_Controls.pdf* with the real thing.

A1. Set Up Azure Management Groups

	DATE / EVIDENCE
☐ Create (or confirm) a Management Group hierarchy under your tenant root	
☐ Create three management groups: <code>Security</code> , <code>Production-Workloads</code> , <code>Sandbox</code>	
☐ Move/assign your production subscription under Production-Workloads; keep a lab subscription under Sandbox	

A2. Create the Azure Policy Definitions

☐ <code>Deny-Disable-Diagnostic-Settings</code> — deny deleting/disabling Diagnostic Settings that export Activity Log/resource logs	
☐ <code>Require-MFA-For-Privileged-Roles</code> — Conditional Access policy requiring MFA for Owner/Contributor sign-in	
☐ <code>Deny-Public-Blob-Access</code> — deny Storage Account configurations that allow anonymous/public blob access	
☐ <code>Require-Resource-Tags</code> — deny untagged VM/Storage/role-assignment creation (Environment, DataClassification, Owner)	
☐ <code>Restrict-Regions</code> — deny resource creation outside the approved region (East US)	

- | | |
|---|--|
| ☐ Assign all five policy definitions to the Production-Workloads management group only (not Sandbox) | |
|---|--|

A3. Mandatory Tagging

- | | |
|--|--|
| ☐ Confirm the Require-Resource-Tags policy enforces Environment , DataClassification , Owner (and CostCenter if used) across the assigned scope | |
|--|--|

A4. Turn On Azure Policy Compliance Checks

- | | |
|--|--|
| ☐ Confirm the policy assignment scope includes HVMC-CloudSecurity-RG | |
| ☐ Add built-in: "MFA should be enabled on accounts with owner permissions on your subscription" | |
| ☐ Add built-in: Diagnostic settings / Activity Log export compliance check | |
| ☐ Add built-in: "Secure transfer to storage accounts should be enabled" | |
| ☐ Add custom policy: required-tags (parameters = your 3 tag keys) | |
| ☐ Schedule an Entra ID access review for stale/unused privileged accounts | |
| ☐ Add built-in: "Management ports should be closed on your virtual machines" | |

A5. Capture Evidence

- | | |
|---|--|
| ☐ Screenshot the Management Group hierarchy and each assigned Azure Policy definition | |
| ☐ Screenshot the Azure Policy compliance dashboard after its first evaluation cycle | |
| ☐ Trigger one blocked action (e.g., create an untagged storage account) and screenshot the denied Activity Log event | |

B. Cloud Security Operations & Incident Response

Replaces the illustrative Activity Log/NSG Flow Log/Defender for Cloud/dashboard/test evidence in *HVMC_Cloud_SecOps_and_Incident_Response.pdf* with the real thing.

B1. Activity Log & Diagnostic Settings

	DATE / EVIDENCE
☐ Create a subscription-wide Diagnostic Setting exporting the Administrative, Security, Alert, and Policy Activity Log categories	
☐ Deliver to both a Log Analytics workspace and a Storage account (with an immutability policy)	
☐ Add a Storage lifecycle management rule: Archive tier at 1 year, expire at 6 years	

B2. NSG Flow Logs

☐ Enable Version 2 NSG Flow Logs (Network Watcher) on <code>HVMC-Web-NSG</code> , <code>HVMC-App-NSG</code> , and <code>HVMC-Data-NSG</code>	
☐ Enable Traffic Analytics, destination = the same Log Analytics workspace as the Activity Log	

B3. Automated Alerting

☐ Create Action Groups: <code>security-critical</code> , <code>security-high</code> , <code>security-medium</code> ; add your email as a notification channel on each	
☐ Azure Monitor alert rule: Global Administrator sign-in or privileged role activation → security-critical	
☐ Azure Monitor alert rule: Azure Policy or role-assignment change → security-high	
☐ Azure Monitor alert rule: NSG rule opened to 0.0.0.0/0 → security-high	
☐ Azure Monitor alert rule: Defender for Cloud alert, severity High or above → security-critical	

B4. Microsoft Defender for Cloud

☐ Enable Microsoft Defender for Cloud on the subscription; set plan administration from the Security management group	
☐ Set auto-provisioning for new resource groups	
☐ Turn on the Defender for Servers, Defender for Storage, and Defender for Containers plans	

B5. Security Dashboard

☐ Create Azure Monitor Workbook <code>HVMC-Security-Operations</code>	
--	--

- | | |
|--|--|
| ☐ Add tiles: Defender for Cloud alerts by severity, Activity Log event volume, Azure Policy compliance ratio, failed/privileged sign-ins, NSG Flow Log denies, open remediation count | |
|--|--|

B6. Test It

- | | |
|---|--|
| ☐ Trigger one harmless test event (e.g., a sign-in from a new location, or an untagged-resource attempt) | |
| ☐ Confirm the alert fires end-to-end (Azure Monitor → Action Group → your inbox) | |
| ☐ Screenshot the workbook and the received alert as your real playbook-test evidence | |

C. Supporting Evidence (Lighter Lift)

These two don't need new infrastructure — just pulling real exports from what should already exist from your JML labs, to replace the illustrative placeholders in those two PDFs.

C1. Compliance Auditing Basics — Real Evidence Pull

☐ Export the real AD/Entra ID user lists (<code>samba-tool user list</code> , Microsoft Entra admin center)	DATE / EVIDENCE
☐ Export a real Activity Log event history sample (7-day window)	
☐ Screenshot the real domain password/lockout policy and Entra ID Conditional Access session settings	

C2. Documentation & Reporting — Retention & Access Control

☐ Add a Storage lifecycle rule on the compliance-documents container matching the 6-year retention schedule	
☐ Apply Azure RBAC role assignments matching the role-based access table (Compliance Auditor = Storage Blob Data Contributor, others = Reader)	

Once these are checked off with real evidence in hand, send me the screenshots/exports (or just say which items are done) and I'll fold the real evidence into the matching PDFs in place of the illustrative placeholders.